Ciberdelitos y Regulación de la Ciberseguridad

Tema 2. Esquema Nacional de Seguridad

Índice

Esquema

Ideas clave

2.1. Introducción y objetivos

2.2. Origen y finalidad del ENS

2.3. Principios del ENS

2.4. Ámbito de aplicación

2.5. Nociones básicas

2.6. Medidas de seguridad del ENS y guías

2.7. Referencias bibliográficas

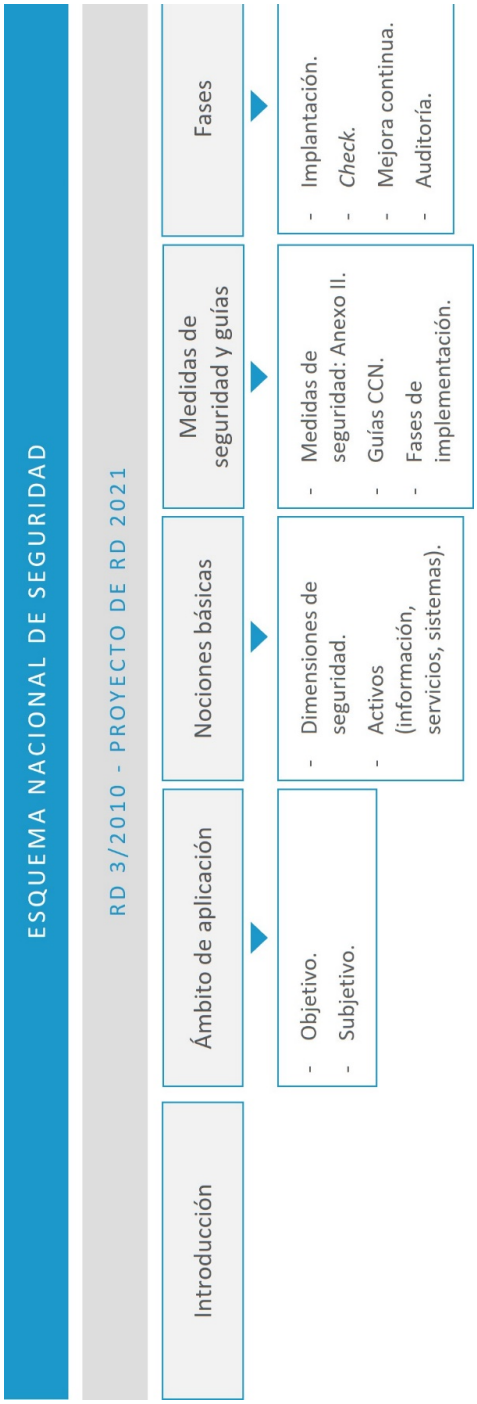
A fondo

Normas y guías de la serie CCN-STIC-800

Portal del Centro Criptológico Nacional dedicado al ENS

Test

Esquema



© Universidad Internacional de La Rioja (UNIR)

2.1. Introducción y objetivos

El Esquema Nacional de Seguridad (en adelante, ENS) es una norma que tiene por objeto determinar la política de seguridad en la utilización de medios electrónicos por parte de las entidades sometidas a su ámbito de aplicación. El ENS está constituido por los principios básicos y requisitos mínimos que garantizan adecuadamente la seguridad de la información tratada.

Los objetivos del presente tema son:

- Conocer el origen y la finalidad del ENS.
- Conocer el marco normativo actual.
- Conocer los principios del ENS.
- Conocer su ámbito de aplicación.
- Adquirir las nociones básicas sobre el ENS.
- Conocer las medidas de seguridad y guías.

© Universidad Internacional de La Rioja (UNIR)

2.2. Origen y finalidad del ENS

La Ley 11/2007, de 22 de junio, de acceso electrónico de los ciudadanos a los Servicios Públicos (LAECSP, actualmente derogada por la Ley 40/2015) trazó el marco normativo básico para la administración electrónica. Pero, ¿qué sería de una administración electrónica si no fuese segura?

Por este motivo creó (art. 42.2) el Esquema Nacional de Seguridad (en adelante, ENS), que posteriormente fue desarrollado, en un primer momento, por el **Real Decreto 3/2010,** de 8 de enero, por el que se regula el Esquema Nacional de Seguridad y, actualmente, por el Real Decreto 311/2022, de 3 de mayo, por el que se regula el Esquema Nacional de Seguridad, que deroga al anterior. El RD 311/2022 introduce novedades —que más adelante se comentarán—, pero mantiene un espíritu continuista con respecto al ENS anterior, por lo que muchas guías del CNN y otros documentos siguen siendo aplicables.

Como indicaba la exposición de motivos del Real Decreto 3/2010, «la necesaria generalización de la sociedad de la información es subsidiaria, en gran medida, de la confianza que genere en los ciudadanos la relación a través de medios electrónicos». No obstante, tal y como señala la exposición de motivos del RD 311/2022, «desde 2010 se han producido notables cambios en España y en la Unión Europea, incluidos la progresiva transformación digital de nuestra sociedad, el nuevo escenario de la ciberseguridad y el avance de las tecnologías de aplicación». Estas modificaciones han hecho necesaria la aprobación de un nuevo esquema nacional de seguridad: «La evolución de las amenazas, los nuevos vectores de ataque, el desarrollo de modernos mecanismos de respuesta y la necesidad de mantener la conformidad y el alineamiento con las regulaciones europeas y nacionales de aplicación, exigen adaptar las medidas de seguridad a esta nueva realidad».

Aunque la LAECSP fue derogada por la Ley 40/2015, de 1 de octubre, de Régimen

© Universidad Internacional de La Rioja (UNIR)

Jurídico del Sector Público (LRJSP), esta última continúa manteniendo el ENS como base de la **seguridad de la administración electrónica** y en ese sentido dispone: «el esquema nacional de seguridad tiene por objeto establecer la política de seguridad en la utilización de medios electrónicos en el ámbito de la presente Ley, y está constituido por los principios básicos y requisitos mínimos que garanticen adecuadamente la seguridad de la información tratada» (art. 156.2, LRJSP).

Así se señala expresamente en el artículo 1.1 del RD 311/2022: «1. Este real decreto tiene por objeto regular el Esquema Nacional de Seguridad (en adelante, ENS), establecido en el artículo 156.2 de la Ley 40/2015, de 1 de octubre, de Régimen Jurídico del Sector Público».

El **Real Decreto por el que se regula el Esquema Nacional de Seguridad** (en adelante, RD 311/2022), indica en su exposición de motivos que sus objetivos son:

> «[1] alinear el ENS con el marco normativo y el contexto estratégico existente para facilitar la seguridad en la Administración Digital […].
>
> »[2] ajustar los requisitos del ENS para adaptarse a la realidad de ciertos colectivos o tipos de sistemas, atendiendo a […] la inclusión en el ENS del concepto de "perfil de cumplimiento específico" que, aprobado por el Centro Criptológico Nacional (CCN), permitan alcanzar una adaptación al ENS más eficaz y eficiente, racionalizando los recursos requeridos sin menoscabo de la protección perseguida y exigible […].
>
> »[3] actualizar el ENS para facilitar una mejor respuesta a las tendencias en ciberseguridad, reducir vulnerabilidades y promover la vigilancia continua, mediante la revisión, a la luz del estado del arte, de los principios básicos, los requisitos mínimos y las medidas de seguridad».

Asimismo, el RD 311/2022 establece en relación con su objeto:

> «El ENS está constituido por los principios básicos y requisitos mínimos necesarios para una protección adecuada de la información tratada y los servicios prestados por las entidades de su ámbito de aplicación, para asegurar el acceso, confidencialidad, integridad, trazabilidad, autenticidad, disponibilidad y conservación de los datos, informaciones y servicios utilizados en medios electrónicos que gestionen en el ejercicio de sus competencias» (art. 1.2).

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Marco normativo y guías de referencia

- Real Decreto 311/2022, de 3 de mayo, por el que se regula el Esquema Nacional de Seguridad.
- Real Decreto 3/2010, de 8 de diciembre, por el que se regula el Esquema Nacional de Seguridad en el ámbito de la Administración Electrónica.
- Real Decreto 951/2015, de 23 de octubre, de modificación del Real Decreto 3/2010, de 8 de enero, por el que se regula el Esquema Nacional de Seguridad en el ámbito de la Administración Electrónica.
- Instrucciones técnicas de seguridad vigentes.
- Guías CCN-STIC serie 800. Esquema Nacional de Seguridad. Centro Criptológico Nacional.
- Guías de aplicabilidad y praxis del Esquema Nacional de Seguridad. Centro Criptológico Nacional.

Otras normas complementarias o referenciadas son:

- Norma ISO/IEC 27001:2013.
- Metodología de Análisis y Gestión de Riesgos IT (MAGERIT).
- Norma ISO 22301:2012. Gestión de la Continuidad.
- Norma ISO 20000-1:2011. Gestión de Servicios.

© Universidad Internacional de La Rioja (UNIR)

2.3. Principios del ENS

Los principios del ENS se enumeran en el artículo 5 del Real Decreto 311/2022:

> «a) Seguridad como proceso integral.
>
> b) Gestión de la seguridad basada en los riesgos.
>
> c) Prevención, detección, respuesta y conservación.
>
> d) Existencia de líneas de defensa.
>
> e) Vigilancia continua.
>
> f) Reevaluación periódica.
>
> g) Diferenciación de responsabilidades» (art. 5, RD 311/2022).

Las diferencias con respecto a los principios vigentes con el anterior ENS (art. 4, RD 3/2010):

- El principio de «prevención, reacción y recuperación» es sustituido por el de «prevención, detección, respuesta y conservación».
- Introducción del principio de «vigilancia continua».

Los principios básicos enmarcan los pilares fundamentales del cumplimiento del ENS y se desarrollan en los artículos 5 a 11. En ellos se refuerza la visión corporativa de la seguridad, así como aspectos organizativos fundamentales (diferenciación de responsabilidades) que definen los diferentes roles, responsabilidades e incompatibilidades que deben tenerse en cuenta en el contexto del ENS.

A continuación, reproducimos dichos artículos:

- Artículo 6. **La seguridad como un proceso integral.**

> «1. La seguridad se entiende como un proceso integral constituido por todos los elementos humanos, materiales, técnicos, jurídicos y organizativos relacionados con el

© Universidad Internacional de La Rioja (UNIR)

sistema de información. La aplicación del ENS estará presidida por este principio, que excluye cualquier actuación puntual o tratamiento coyuntural.

2. Se prestará la máxima atención a la concienciación de las personas que intervienen en el proceso y la de los responsables jerárquicos, para evitar que, la ignorancia, la falta de organización y de coordinación o de instrucciones adecuadas, constituyan fuentes de riesgo para la seguridad».

- Artículo 7. **Gestión de la seguridad basada en los riesgos.**

«1. El análisis y la gestión de los riesgos es parte esencial del proceso de seguridad, debiendo constituir una actividad continua y permanentemente actualizada.

2. La gestión de los riesgos permitirá el mantenimiento de un entorno controlado, minimizando los riesgos a niveles aceptables. La reducción a estos niveles se realizará mediante una apropiada aplicación de medidas de seguridad, de manera equilibrada y proporcionada a la naturaleza de la información tratada, de los servicios a prestar y de los riesgos a los que estén expuestos».

- Artículo 8. **Prevención, detección, respuesta y conservación.**

«1. La seguridad del sistema debe contemplar las acciones relativas a los aspectos de prevención, detección y respuesta, al objeto de minimizar sus vulnerabilidades y lograr que las amenazas sobre el mismo no se materialicen o que, en el caso de hacerlo, no afecten gravemente a la información que maneja o a los servicios que presta.

2. Las medidas de prevención, que podrán incorporar componentes orientados a la disuasión o a la reducción de la superficie de exposición, deben eliminar o reducir la posibilidad de que las amenazas lleguen a materializarse.

3. Las medidas de detección irán dirigidas a descubrir la presencia de un ciberincidente.

4. Las medidas de respuesta, que se gestionarán en tiempo oportuno, estarán orientadas a la restauración de la información y los servicios que pudieran haberse visto afectados por un incidente de seguridad.

5. Sin merma de los restantes principios básicos y requisitos mínimos establecidos, el sistema de información garantizará la conservación de los datos e información en soporte electrónico.

De igual modo, el sistema mantendrá disponibles los servicios durante todo el ciclo vital de la información digital, a través de una concepción y procedimientos que sean la base

© Universidad Internacional de La Rioja (UNIR)

para la preservación del patrimonio digital».

- Artículo 9. **Existencia de líneas de defensa.**

  «1. El sistema de información ha de disponer de una estrategia de protección constituida por múltiples capas de seguridad, dispuesta de forma que, cuando una de las capas sea comprometida, permita:

  a) Desarrollar una reacción adecuada frente a los incidentes que no han podido evitarse, reduciendo la probabilidad de que el sistema sea comprometido en su conjunto.

  b) Minimizar el impacto final sobre el mismo.

  2. Las líneas de defensa han de estar constituidas por medidas de naturaleza organizativa, física y lógica».

- Artículo 10. **Vigilancia continua y reevaluación periódica.**

  «1. La vigilancia continua permitirá la detección de actividades o comportamientos anómalos y su oportuna respuesta.

  2. La evaluación permanente del estado de la seguridad de los activos permitirá medir su evolución, detectando vulnerabilidades e identificando deficiencias de configuración.

  3.Las medidas de seguridad se reevaluarán y actualizarán periódicamente, adecuando su eficacia a la evolución de los riesgos y los sistemas de protección, pudiendo llegar a un replanteamiento de la seguridad, si fuese necesario».

- Artículo 11. **Diferenciación de responsabilidades.**

  «1. En los sistemas de información se diferenciará el responsable de la información, el responsable del servicio, el responsable de la seguridad y el responsable del sistema.

  2. La responsabilidad de la seguridad de los sistemas de información estará diferenciada de la responsabilidad sobre la explotación de los sistemas de información concernidos.

  3. La política de seguridad de la organización detallará las atribuciones de cada responsable y los mecanismos de coordinación y resolución de conflictos».

© Universidad Internacional de La Rioja (UNIR)

2.4. Ámbito de aplicación

Ámbito subjetivo

El **ámbito de aplicación subjetivo** se indica en el artículo 2 del Real Decreto 311/2022:

> «1. El presente real decreto es de aplicación a **todo el sector público**, en los términos en que este se define por el **artículo 2 de la Ley 40/2015**, de 1 de octubre, y de acuerdo con lo previsto en el artículo 156.2 de la misma.
>
> 2. Asimismo, sin perjuicio de la aplicación de la Ley 9/1968, de 5 de abril, de Secretos Oficiales y otra normativa especial, este real decreto será de aplicación a los **sistemas que tratan información clasificada**, pudiendo resultar necesario adoptar medidas complementarias de seguridad, específicas para dichos sistemas, derivadas de los compromisos internacionales contraídos por España o de su pertenencia a organismos o foros internacionales.
>
> 3. Este real decreto también se aplica a los **sistemas de información de las entidades del sector privado**, incluida la obligación de contar con la política de seguridad a que se refiere el artículo 12, cuando, de acuerdo con la normativa aplicable y en virtud de una relación contractual, **presten servicios o provean soluciones a las entidades del sector público** para el ejercicio por estas de sus competencias y potestades administrativas.
>
> La política de seguridad a que se refiere el artículo 12 será aprobada en el caso de estas entidades por el órgano que ostente las máximas competencias ejecutivas.
>
> Los **pliegos de prescripciones administrativas o técnicas** de los contratos que celebren las entidades del sector público incluidas en el ámbito de aplicación de este real decreto **contemplarán todos aquellos requisitos necesarios para asegurar la conformidad con el ENS** de los sistemas de información en los que se sustenten los servicios prestados por los contratistas, tales como la presentación de las correspondientes Declaraciones o Certificaciones de Conformidad con el ENS.
>
> Esta cautela se extenderá también a la **cadena de suministro de dichos contratistas**, en la medida que sea necesario y de acuerdo con los resultados del correspondiente análisis de riesgos (…)».

© Universidad Internacional de La Rioja (UNIR)

Por su parte, el artículo 2 de la LRJSP establece:

> «1. La presente Ley se aplica al sector público que comprende:
>
> »a) La Administración General del Estado.
>
> »b) Las Administraciones de las Comunidades Autónomas.
>
> »c) Las Entidades que integran la Administración Local.
>
> »d) El sector público institucional.
>
> »2. El sector público institucional se integra por:
>
> »a) Cualesquiera organismos públicos y entidades de derecho público vinculados o dependientes de las Administraciones Públicas.
>
> »b) Las entidades de derecho privado vinculadas o dependientes de las Administraciones Públicas que quedarán sujetas a lo dispuesto en las normas de esta Ley que específicamente se refieran a las mismas, en particular a los principios previstos en el artículo 3, y en todo caso, cuando ejerzan potestades administrativas.
>
> »c) Las Universidades públicas que se regirán por su normativa específica y supletoriamente por las previsiones de la presente Ley.
>
> »3. Tienen la consideración de Administraciones Públicas la Administración General del Estado, las Administraciones de las Comunidades Autónomas, las Entidades que integran la Administración Local, así como los organismos públicos y entidades de derecho público previstos en la letra a) del apartado 2» (art. 2, LRJSP).

Pero dentro de lo que es el sector público hay una amplia amalgama de entes. Asimismo, existen entidades (como, por ejemplo, los colegios profesionales) que tienen una **naturaleza bifronte o mixta** (en parte pública y en parte privada).

Sobre la aplicabilidad del ENS a empresas privadas que sean proveedoras de servicios a la administración, es notorio que la participación del sector privado en la prestación de servicios y en la provisión de productos o soluciones a las entidades públicas sea cada vez más frecuente. Por ello, el RD 311/2022 las incluye expresamente en el párrafo tercero del artículo 2.

Con anterioridad al RD 311/2022, la guía técnica del CCN-STIC-830 (ámbito de

© Universidad Internacional de La Rioja (UNIR)

aplicación del esquema nacional de seguridad) establecía claramente:

> «47. Las soluciones tecnológicas o los servicios comprendidos dentro del ámbito objetivo de aplicación del Esquema Nacional de Seguridad, cuando sean suministrados o prestados por organizaciones privadas, habrán de satisfacer las exigencias legales establecidas en el mismo.
>
> »48. Por ello, las entidades a las que se destinan las soluciones o sean titulares de los servicios prestados, indicados en el párrafo anterior, exigirán a las organizaciones privadas suministradoras o prestadoras, respectivamente, la conformidad con el ENS de sus soluciones o servicios, en los términos establecidos en la Declaración o Certificación de Conformidad con el ENS, utilizando los criterios y procedimientos previstos en la Guía CCN-STIC-809 "Declaración y Certificación de Conformidad con el ENS y Distintivos de Cumplimiento"» (CCN, 2016b, p. 14).

Ámbito objetivo

Visto el ámbito subjetivo del ENS (las organizaciones en las que se aplicará), corresponde tener claro cuál es el **alcance objetivo** del ENS o, dicho de otra forma, cuáles van a ser los «elementos» (utilizamos este concepto por su sentido lato que después será concretado) que entrarán en el alcance.

En el segundo párrafo de la exposición de motivos del RD 311/2022 se plasma la finalidad perseguida por el ENS:

> «fundamentar la confianza en que los sistemas de información prestaran sus servicios y custodiaran la información sin interrupciones o modificaciones fuera de control, y sin que la información pudiera llegar a personas no autorizadas, a través de medidas para garantizar la seguridad de los sistemas, los datos, las comunicaciones y los servicios electrónicos, que permitiera a los ciudadanos y a las Administraciones públicas, el ejercicio de sus derechos y el cumplimiento de sus deberes a través de estos medios».

Esta finalidad incluye los aspectos fundamentales de su ámbito objetivo enumerando sistemas, datos, comunicaciones y servicios electrónicos implicados en el ejercicio de derechos y el cumplimiento de deberes por parte de los ciudadanos ante las administraciones públicas.

© Universidad Internacional de La Rioja (UNIR)

El ámbito objetivo de aplicación fue objeto de numerosas interpretaciones y consultas sobre su alcance real. **El CCN es el organismo que ha recogido, evaluado y respondido** a estas cuestiones, y ha publicado un documento donde se recogen las preguntas frecuentes con sus respuestas y los considerandos sobre estas. De esta forma se abre un foro de interpretación práctica de gran utilidad ante la casuística que se deriva de los servicios electrónicos municipales y su afectación por el ENS.

La anteriormente citada Guía CCN-STIC-830 aborda el ámbito objetivo en los siguientes términos:

> «36. […] **bastará que el sistema de información en cuestión** (cuando esté sustentado en medios electrónicos) s**e dirija a gestionar las competencias de la entidad pública correspondiente** (que deberá estar incluida en su ámbito subjetivo de aplicación) **para que le sea de aplicación el ENS.**
>
> »37. Sobre este particular conviene señalar que el concepto ***"sistema de información"*** es muy amplio y que, atendiendo a lo señalado en UNE-ISO/IEC 27000:2014 podemos definirlo como *"Conjunto de aplicaciones, servicios, activos relacionados con tecnologías de la información y otros componentes para manejar información"*» (CCN, 2016b, p. 11).

Por tanto, partiendo de que el mandato legal del ENS lo constituye esencialmente la protección de la información tratada y los servicios prestados, conviene recordar que el ENS debe aplicarse técnicamente a todos los elementos que, en relación con tales informaciones o servicios, puedan ser directa o indirectamente atacados.

Estos elementos se detallan en el Anexo IV del ENS: «Activo: componente o funcionalidad de un sistema de información susceptible de ser atacado deliberada o accidentalmente con consecuencias para la organización. Incluye: información, datos, servicios, aplicaciones (software), equipos (hardware), comunicaciones, recursos administrativos, recursos físicos y recursos humanos».

Finalmente, y atendiendo a la exigencia de desenvolvimiento electrónico que prescriben las leyes 39/2015 (LPACAP) y 40/2015 (LRJSP), el marco de aplicación material señalado en el párrafo anterior se concretará en todas y cada una de las

© Universidad Internacional de La Rioja (UNIR)

actuaciones de las entidades públicas del ámbito subjetivo de aplicación del ENS que desarrollen o contribuyan a desarrollar el procedimiento administrativo.

Así, entre otras, **el ENS se aplicará en** todo lo relativo a:

- Facilitar, por medios electrónicos, el derecho de los ciudadanos a relacionarse electrónicamente con las administraciones públicas.
- Facilitar, por medios electrónicos, los derechos de los ciudadanos en su calidad de interesados en el procedimiento administrativo (arts. 13, 28, 53 y 66.1b, LPACAP).
- Facilitar el uso de los medios de identificación y firma electrónica de los interesados en el procedimiento administrativo incluyendo su representación y los registros electrónicos de apoderamientos (arts. 9-11, 5 y 6, LRJSP).
- Facilitar, por medios electrónicos, el derecho de los interesados a ser asistidos en el uso de los medios electrónicos en sus relaciones con las AA. PP. (arts. 12 y 13, LPACAP).
- Facilitar a los ciudadanos, por medios electrónicos, el derecho de información (arts. 21.4, 27.3 y DA 4, LPACAP).
- Los registros electrónicos (art. 16, LPACAP).
- El archivo electrónico de documentos y expedientes (art. 17, LPACAP).
- La tramitación electrónica de los procedimientos incluyendo el cómputo de plazos, la notificación electrónica, la gestión electrónica de expedientes y la tramitación electrónica del procedimiento, en general (arts. 30, 41-43, 70 y Título IV, LPACAP).
- La relación por medios electrónicos entre las propias entidades de las AA. PP., sus órganos, organismos públicos y entidades vinculadas o dependientes (art. 3, LRJSP).
- El funcionamiento electrónico de la administración incluyendo las sedes electrónicas

© Universidad Internacional de La Rioja (UNIR)

y los portales de Internet, los sistemas de identificación y firma, la actuación administrativa automatizada, el intercambio electrónico de datos en entornos cerrados, el aseguramiento de la interoperabilidad de la firma electrónica y el archivo electrónico de documentos (arts. 38, 39, 40-43, 44-46, LRJSP).

- Las relaciones electrónicas entre las administraciones incluyendo las transmisiones de datos entre AA. PP., ENI y ENS, la reutilización de sistemas y aplicaciones y la transferencia de tecnologías (arts. 155-158, LRJSP).

Algunos **ejemplos** de lo anterior son:

- El archivo electrónico de los procedimientos administrativos desarrollados, por ser un sistema de información para el desarrollo del procedimiento administrativo de la entidad.
- El sistema de gestión de vacantes de un hospital público, por ser un sistema de información para el cumplimiento de deberes del hospital.
- La gestión de los expedientes académicos de los alumnos de una universidad pública, por ser un sistema de información para el desarrollo de las funciones competenciales de la universidad.
- La gestión de las citas para la obtención del DNI, por ser un sistema de información para el cumplimiento de deberes de los ciudadanos.
- La gestión de los procedimientos sancionadores, por ser un sistema de información para el desarrollo del procedimiento administrativo de la entidad.
- La gestión del padrón de un ayuntamiento, por ser un sistema de información para el desarrollo de las funciones competenciales del ayuntamiento.
- El perfil del contratante, por ser un sistema de información accesible electrónicamente por las empresas para el ejercicio de derechos.
- La gestión de la contabilidad, por ser un sistema de información para el cumplimiento

© Universidad Internacional de La Rioja (UNIR)

de deberes de la entidad.

- La gestión de recursos humanos, por ser un sistema de información para el ejercicio de derechos de los empleados.
- La tramitación legislativa, por ser un sistema de información para el desarrollo de las funciones competenciales de la entidad.
- La gestión tributaria, por ser un sistema de información para el desarrollo de las funciones competenciales de la entidad.

No obstante, por los importantes beneficios que se derivan de ello, **siempre resulta conveniente aplicar el ENS** a todos los sistemas de las entidades, incluso los que contenga información de transparencia o pública excluida de toda confidencialidad, ya que constituye la herramienta más adecuada para preservar las debidas garantías y dimensiones que estos necesitan, tales como disponibilidad, integridad, trazabilidad y autenticidad.

© Universidad Internacional de La Rioja (UNIR)

2.5. Nociones básicas

Política de seguridad y requisitos mínimos de seguridad

Se especifican en el Capítulo III del RD 311/2022:

- Artículo 12. Política de seguridad y requisitos mínimos de seguridad.
- Artículo 13. Organización e implantación del proceso de seguridad.
- Artículo 14. Análisis y gestión de los riesgos.
- Artículo 15. Gestión de personal.
- Artículo 16. Profesionalidad.
- Artículo 17. Autorización y control de los accesos.
- Artículo 18. Protección de las instalaciones.
- Artículo 19. Adquisición de productos de seguridad y contratación de servicios de seguridad.
- Artículo 20. Mínimo privilegio.
- Artículo 21. Integridad y actualización del sistema.
- Artículo 22. Protección de información almacenada y en tránsito.
- Artículo 23. Prevención ante otros sistemas de información interconectados.
- Artículo 24. Registro de actividad y detección de código dañino.
- Artículo 25. Incidentes de seguridad.
- Artículo 26. Continuidad de la actividad.

© Universidad Internacional de La Rioja (UNIR)

- Artículo 27. Mejora continua del proceso de seguridad.
- Artículo 28. Cumplimiento de los requisitos mínimos.
- Artículo 29. Infraestructuras y servicios comunes.
- Artículo 30. Perfiles de cumplimiento específicos y acreditación de entidades de implementación de configuraciones seguras.

Estos requisitos son desarrollados en los artículos 12 a 30 del RD 311/2022. En ellos se establecen las iniciativas que se deben impulsar para una implementación completa del ENS.

Entre los requisitos mínimos pueden observarse claras coincidencias con los objetivos de control de otras normas relacionadas con la seguridad de la información, como la ISO/IEC 27001. Si bien, en el caso del ENS, el conjunto de medidas aplicables contempla el factor de proporcionalidad marcado por la categorización de los sistemas y, con ello, se facilita en gran medida la selección de las medidas.

Dimensiones de seguridad del ENS

El ENS trata las siguientes dimensiones de la seguridad. Estas definiciones se han extraído de la Guía CCN-STIC-800 (Esquema Nacional de Seguridad. Glosario de términos y abreviaturas):

- **Disponibilidad:** «propiedad o característica de los activos consistente en que las entidades o procesos autorizados tienen acceso a los mismos cuando lo requieren» (CCN, 2016a, p. 14).
- **Integridad:** «propiedad o característica consistente en que el activo de información no ha sido alterado de manera no autorizada» (CCN, 2016a, p. 18).
- **Confidencialidad:** «propiedad o característica consistente en que la información ni se pone a disposición, ni se revela a individuos, entidades o procesos no

© Universidad Internacional de La Rioja (UNIR)

autorizados» (CCN, 2016a, p. 12).

- **Trazabilidad:** «propiedad o característica consistente en que las actuaciones de una entidad pueden ser imputadas exclusivamente a dicha entidad» (CCN, 2016a, p. 31).
- **Autenticidad:** «propiedad o característica consistente en que una entidad es quien dice ser o bien que garantiza la fuente de la que proceden los datos» (CCN, 2016a, p. 9).

Con base en estas dimensiones se calculan los impactos que tendrían los incidentes de seguridad sobre los sistemas afectados por el ENS y con ello se determinaría su categorización (básico, medio o alto).

En el Anexo I del RD 311/2022 se establece que:

> «A fin de determinar el impacto que tendría sobre la organización un incidente que afectara a la seguridad de la información tratada o de los servicios prestados y, en su consecuencia, establecer la categoría de seguridad del sistema de información en cuestión, se tendrán en cuenta las siguientes dimensiones de la seguridad, que se identificarán por sus correspondientes iniciales en mayúsculas:
>
> a) Confidencialidad [C].
>
> b) Integridad [I].
>
> c) Trazabilidad [T].
>
> d) Autenticidad [A].
>
> e) Disponibilidad [D]».

Activos de alto nivel: información, servicios y sistemas

Estos tres conceptos básicos constituyen los activos de alto nivel en un contexto de cumplimiento del ENS.

Todos los conceptos son analizados desde la perspectiva de las cinco dimensiones expuestas, aun cuando en función de su naturaleza se hace especial énfasis en las dimensiones que les pueden afectar en mayor medida.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Información: existen muy diversas definiciones del término *información.* Una de ellas la expone como «información es cualquier conjunto de datos que tienen significado» (CCN, 2017, p. 14). El ENS se limita a valorar aquellos tipos de información que son relevantes para el proceso administrativo y pueden ser tratados en algún servicio afecto a la LRJSP. Las dimensiones básicas de la información son:

- Confidencialidad.
- Integridad.

En la información confluyen los requerimientos marcados por el RGPD y la LOPDGDD. De hecho, cuando se trata de información de carácter personal, son estos marcos los que regulan en mayor medida su categorización.

Servicio: su definición ya ha sido expuesta anteriormente. Su dimensión básica es la disponibilidad. Los servicios tratan y procesan información heredando las valoraciones de esta en sus dimensiones correspondientes.

Sistema de información: esta definición ya ha sido expuesta anteriormente. En el contexto del ENS, un sistema de información contiene los recursos necesarios para materializar los servicios de su catálogo, por lo que, en la práctica, está compuesto tanto por dichos servicios como por las informaciones que estos manejan.

En la práctica, es habitual asociar sistemas de información con aplicaciones concretas que ofrecen funcionalidades a un área determinada.

© Universidad Internacional de La Rioja (UNIR)



Figura 1. Activos. Fuente: Poveda, s. f.

© Universidad Internacional de La Rioja (UNIR)

2.6. Medidas de seguridad del ENS y guías

Medidas de seguridad

Las medidas de seguridad del ENS se encuentran especificadas en el Anexo II del RD 311/2022:

> «1. Para lograr el cumplimiento de los principios básicos y requisitos mínimos establecidos se aplicarán las medidas de seguridad indicadas en este anexo, las cuales serán proporcionales a:
>
> a) Las dimensiones de seguridad relevantes en el sistema a proteger.
>
> b) La categoría de seguridad del sistema de información a proteger.
>
> 2. Las medidas de seguridad se dividen en tres grupos:
>
> a) Marco organizativo [org]. Constituido por el conjunto de medidas relacionadas con la organización global de la seguridad.
>
> b) Marco operacional [op]. Formado por las medidas a tomar para proteger la operación del sistema como conjunto integral de componentes para un fin.
>
> c) Medidas de protección [mp]. Se centran en proteger activos concretos, según su naturaleza y la calidad exigida por el nivel de seguridad de las dimensiones afectadas».

Estas medidas de seguridad se desglosan en acciones de implementación (Guía CCN-STIC-804) y se verifican mediante la Guía CCN-STIC-808.

En el RD 311/2022, las 73 medidas iniciales se convierten en más de 400 acciones, por lo que el grado de detalle para las iniciativas de cumplimiento y acreditación es elevado. Con ello se facilita de forma significativa la elaboración de los planes, presupuestos y, en general, las iniciativas tendentes a conseguir el adecuado grado de cumplimiento con el ENS.

El RD 311/2022 introduce alguna modificación con respecto a la norma anterior:

© Universidad Internacional de La Rioja (UNIR)



Figura 2. Medidas de seguridad RD 311/2022. Fuente: elaboración propia.

Como evidencia del continuismo del RD 311/2022 en relación con el anterior ENS, adjuntamos una comparativa de las medidas de seguridad en ambas normas:

© Universidad Internacional de La Rioja (UNIR)



Figura 3. Fuente: Infografía del CCN. https://ens.ccn.cni.es/es/docman/documentos-publicos/818-infografia-04-ens-2010-ens-2022-diferencias-y-evolucion/file

Una novedad introducida por el RD 311/2022 son los Perfiles de Cumplimiento Específico (PCE).

Según se indica en el Anexo IV, es el «conjunto de medidas de seguridad, comprendidas o no en el anexo II de este real decreto, que, como consecuencia del preceptivo análisis de riesgos, resulten de aplicación a una entidad o sector de actividad concreta y para una determinada categoría de seguridad, y que haya sido

© Universidad Internacional de La Rioja (UNIR)

habilitado por el CCN».

Según indica el CCN en sus preguntas frecuentes sobre el ENS:

> «Los PCE deben ser aprobados por el Centro Criptológico Nacional, permitiendo alcanzar una adaptación del ENS más eficaz y eficiente, racionalizando los recursos requeridos sin menoscabo de la protección perseguida y exigible.
>
> Cuando la implementación de un PCE requiera configuraciones de seguridad específicas, en función de las distintas tecnologías, se publicará junto con las correspondientes Guías STIC de Configuración.
>
> Hasta la fecha se dispone de PCE para EE.LL., Universidades y Servicios en la Nube».

Sobre esta cuestión, en noviembre de 2022 se ha publicado la *Guía Perfil de Cumplimiento Específico de Requisitos Esenciales de Seguridad*.

También, como novedad, se introduce un **nuevo sistema de codificación** de los requisitos de las medidas de seguridad.

Tal y como se afirma en la exposición de motivos del RD 311/2022:

> «La modificación del marco táctico y operativo en el que se desenvuelven las ciberamenazas y sus correlativas salvaguardas ha obligado a actualizar el elenco de medidas de seguridad del anexo II, con objeto de añadir, eliminar o modificar controles y subcentrales, al tiempo que se incluye un nuevo sistema de referencias más moderno y adecuado, sobre la base de la existencia de un requisito general y de unos posibles refuerzos, alineados con el nivel de seguridad perseguido».

Así, se han codificado los requisitos de medidas y se han organizado de la siguiente forma:

- Requisitos base.
- Posibles **refuerzos de seguridad (R)**, alineados con el nivel de seguridad perseguido, que se suman (+) a los requisitos base de la medida, pero que no siempre son incrementales entre sí; de forma que, en ciertos casos se puede elegir entre aplicar un refuerzo u otro.

© Universidad Internacional de La Rioja (UNIR)

Medidas de Seguridad		Por categoría o dimensión(es)	Nivel de las dimensiones de seguridad		
			BAJO	MEDIO	ALTO
			Categoría de seguridad del sistema		
			BÁSICA	MEDIA	ALTA
org	Marco organizativo				
org.1	Política de seguridad	Categoría	aplica	aplica	aplica
org.2	Normativa de seguridad	Categoría	aplica	aplica	aplica
org.3	Procedimientos de seguridad	Categoría	aplica	aplica	aplica
org.4	Proceso de autorización	Categoría	aplica	aplica	aplica
op	Marco operacional				
op.pl	Planificación				
op.pl.1	Análisis de riesgos	Categoría	aplica	+ R1	+ R2
op.pl.2	Arquitectura de Seguridad	Categoría	aplica	+ R1	+ R1 + R2 + R3

Figura 4. Anexo II: Medidas de seguridad ENS (RD 311/2022).

Para señalar que se puede elegir entre aplicar un refuerzo u otro, se indicará entre corchetes y separados por «o» [Rn o Rn+1].

mp.com	Protección de las comunicaciones				
mp.com.1	Perímetro seguro	Categoría	aplica	aplica	aplica
mp.com.2	Protección de la confidencialidad	C	aplica	+ R1	+ R1 + R2 + R3
mp.com.3	Protección de la integridad y de la autenticidad	I A	aplica	+ R1 + R2	+ R1 + R2 + R3 + R4
mp.com.4	Separación de flujos de información en la red	Categoría	n.a.	+ [R1 o R2 o R3]	+ [R2 o R3] + R4

Figura 5. Anexo II: Medidas de seguridad ENS (RD 311/2022).

Guías de implementación y control del ENS

En cumplimiento con el artículo 37.1.b del ENS, el CCN ha desarrollado un amplio conjunto de guías sobre diferentes aspectos de la implementación, gestión y control del ENS. Estas se encuentran en la serie CCN-STIC-800.

En la misma línea, el artículo 4.3 del PRD establece: «para el mejor cumplimiento de lo establecido en el presente real decreto, el CCN, en el ejercicio de sus competencias, elaborará y difundirá las correspondientes guías de seguridad de las tecnologías de la información y la comunicación (Guías CCN-STIC), que se incorporarán al conjunto documental utilizado para la realización de las auditorías de seguridad».

Asimismo, en el proyecto se prevé que el Ministerio de Asuntos Económicos y Transformación Digital, a propuesta de la Comisión Sectorial de Administración Electrónica y por iniciativa del CCN, apruebe las instrucciones técnicas de seguridad

© Universidad Internacional de La Rioja (UNIR)

de obligado cumplimiento, que se publicarán mediante una resolución de la Secretaría de Estado, Digitalización e Inteligencia Artificial (art. 4.1, PRD).

En relación con las guías de seguridad publicadas por el CCN, a continuación, relacionamos las principales.

Guía 800. Glosario de términos y abreviaturas del ENS

Recoge aquellos términos y abreviaturas utilizados en las guías de desarrollo del ENS.

Guía 801. Responsable y funciones en el esquema nacional de seguridad

El objeto de esta guía es crear un marco de referencia que establezca las responsabilidades generales en la gestión de la seguridad de los sistemas, así como proponer unas figuras o roles de seguridad que las implementen.

Guía 802. Auditoría del esquema nacional de seguridad

Esta guía de auditoría del ENS se encuadra dentro de lo previsto en el artículo 42 de la Ley 11/2007, de 22 de junio, de acceso electrónico de los ciudadanos a los Servicios Públicos, y específicamente dentro de los requisitos del artículo 34 (auditoría de la seguridad) y del anexo III (auditoría de la seguridad) del RD 3/2010.

Guía 803. Valoración de sistemas en el esquema nacional de seguridad

El ENS establece una serie de medidas de protección en su anexo II que están condicionadas a la valoración del nivel de seguridad en cada dimensión y a la categoría (artículo 43) del sistema de información del que se trate. A su vez, la categoría del sistema se calcula en función del nivel de seguridad en cada dimensión. Esta guía establece unas pautas de carácter general que son aplicables a entidades de distinta naturaleza, dimensión y sensibilidad sin entrar en casuísticas particulares.

Guía 804. Medidas de implantación del esquema nacional de seguridad

El ENS establece una serie de medidas de seguridad en su anexo II que están condicionadas a la valoración del nivel de seguridad en cada dimensión y a la categoría (artículo 43) del sistema de información del que se trate. A su vez, la categoría del sistema se calcula en función del nivel de seguridad en cada dimensión. Esta guía establece unas pautas de carácter general que son aplicables a entidades de distinta naturaleza, dimensión y sensibilidad sin entrar en casuísticas particulares.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Guía 805. Políticas de seguridad de la información

La política de seguridad de la información es un documento de alto nivel que define lo que significa «seguridad de la información» en una organización. El documento debe estar accesible para todos los miembros de la organización y redactado de forma sencilla, precisa y comprensible.

Guía 806. Plan de adecuación del esquema nacional de seguridad

Los sistemas existentes a la entrada en vigor del RD 3/2010 deberán adecuarse al ENS de forma que permitan el cumplimiento de lo establecido en la disposición final tercera de la Ley 11/2007. Esta guía establece unas pautas de carácter general que son aplicables a entidades de distinta naturaleza, dimensión y sensibilidad sin entrar en casuísticas particulares.

Guía 807. Criptología de empleo en el esquema nacional de seguridad

Esta guía desarrolla las recomendaciones sobre algoritmos y parámetros criptológicos recogidas en el esquema nacional de seguridad.

Guía 808. Verificación del cumplimiento de las medidas en el esquema nacional de seguridad

El objeto de esta guía es que sirva tanto de itinerario como de registro a aquella persona designada como auditor de los requisitos del esquema nacional de seguridad para un sistema.

Guía 809. Declaración de conformidad del esquema nacional de seguridad

La presente guía tiene por objeto dar pautas generales para la aplicación de lo dispuesto en el artículo 41 del ESN, sin perjuicio de la particularización de cada organismo.

Guía 810. Creación de un CERT/CSIRT

Esta guía forma parte del desarrollo del RD 3/2010 del ENS, según se alude en el artículo 37 sobre prestación de servicios de respuesta a incidentes de seguridad en las administraciones públicas y, específicamente, en su punto número 2 sobre el programa desarrollado por el CCN para que las administraciones públicas puedan desarrollar sus propias capacidades de respuesta a incidentes de seguridad.

Guía 811. Interconexión en el esquema nacional de seguridad

El ESN, en su artículo 22, establece la obligatoriedad de proteger el perímetro de los sistemas interconectados (en particular, si se utilizan redes públicas total o parcialmente) y de analizar los riesgos derivados de la interconexión de los sistemas, controlando, además, su punto de unión.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Guía 812. Seguridad en entornos y aplicaciones web

Guía de referencia en la identificación y el análisis de los requisitos de seguridad asociados a las aplicaciones y entornos web en el ámbito del ENS, con el objetivo de reducir las posibles amenazas de seguridad asociadas a estos entornos y aplicaciones durante su diseño y antes de su paso a producción.

Guía 813. Componentes certificados en el ENS

Esta guía introduce los conceptos y define los criterios específicos que deben guiar y ayudar en la aplicación de los requisitos de adquisición y uso de componentes certificados en el ENS.

Guía 814. Seguridad en correo electrónico

Guía de configuración segura del correo electrónico en el ámbito del ENS con el objetivo de reducir las posibles amenazas de seguridad asociadas a estos entornos.

Guía 815. Métricas e indicadores en el esquema nacional de seguridad

Esta guía persigue proponer un conjunto de datos que registrar del sistema de información a fin de poder derivar métricas posteriormente, tanto locales del sistema como del conjunto de la administración: un conjunto amplio de métricas o indicadores para caracterizar los puntos del anexo II del ENS; un conjunto reducido de métricas o indicadores para caracterizar la posición del sistema de información en materia de seguridad de la información; y cuadros de mando para escenarios típicos.

Guía 817. Criterios comunes para la gestión de incidentes de seguridad

Con el fin de comunicar y compartir información con claridad sobre incidentes, es necesario adoptar una terminología común que describa todos aquellos posibles de materializarse. Solo partiendo de las mismas premisas y siguiendo las mismas definiciones se puede coordinar una respuesta rápida y eficaz. Esta guía recoge un conjunto de conceptos y descripciones de alto nivel que permiten mejorar las comunicaciones entre los distintos responsables de seguridad de las AA. PP.

Guía 818. Herramientas de seguridad en el ENS

Esta guía persigue el doble objetivo de describir y clasificar las diferentes herramientas de seguridad existentes, así como establecer los requisitos relativos a la selección, aprobación, implementación, uso y mantenimiento de dichas herramientas de seguridad en los sistemas.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Guía 820. Protección contra denegación de servicios

El objeto de la guía es definir en qué consiste un ataque de denegación de servicio, qué tipos de ataques existen y cómo clasificarlos. Define qué factores se deben tener en cuenta a la hora diseñar protecciones contra ataques de denegación de servicio. Describe qué mitigaciones deben ser aplicadas para cumplir los requisitos del ENS en el ámbito de la administración electrónica en cuanto a protección contra ataques de denegación de servicio.

Guía 821. Normas de seguridad en el ENS

El objetivo de esta guía es proponer a los organismos de las administraciones públicas españolas una relación de normas de seguridad recogiendo lo exigido por el RD 3/2010.

Guía 822. Normas de seguridad en el ENS

El objetivo de esta guía es proponer a los organismos de las administraciones públicas españolas una relación de procedimientos de seguridad recogiendo lo exigido por el RD 3/2010. La normativa contenida en la presente guía resulta de aplicación a cualquier entidad del sector público del ámbito de la Ley 11/2007: Administración General del Estado, Administración de las Comunidades Autónomas y Administración de las Entidades Locales.

Guía 823. Seguridad en entornos *cloud*

Esta guía recoge los aspectos de seguridad necesarios que deberán contemplarse para la adopción del *cloud computing* como paradigma tecnológico para la disposición de servicios con las garantías de seguridad pertinentes. Se han identificado las medidas de seguridad y los requisitos que deben cumplir los proveedores de servicios para dar cumplimiento tanto a los marcos legislativos aplicables, en especial el ENS o la normativa vigente en materia de protección de datos personales, como a los códigos de buenas prácticas o estándares reconocidos internacionalmente.

Guía 824. Informe del estado de seguridad

Este documento describe una serie de medidas e indicadores con dos destinatarios: el propio organismo propietario del sistema de información y el informe anual del estado de seguridad de la Administración pública española. En ambos casos se busca una estimación preventiva de la seguridad, vía análisis del cumplimiento de determinados aspectos que se han estimado críticos para cualquier organismo, una estimación de la eficacia y eficiencia de las actividades en materia de seguridad y una estimación del esfuerzo humano y económico dedicado a seguridad TIC.

© Universidad Internacional de La Rioja (UNIR)

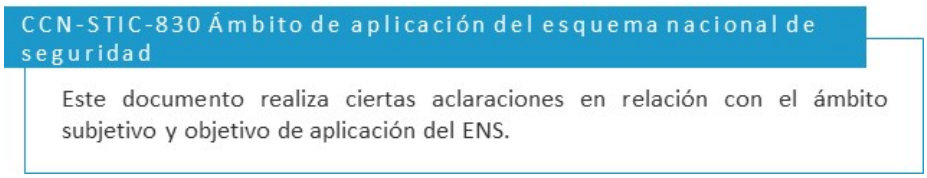


Figura 6. Guías de seguridad publicadas por el CCN. Fuente: elaboración propia.

El cumplimiento del ENS se plantea como un proyecto en varias fases, siguiendo la metodología marcada por su texto, las guías CCN-STIC, instrucciones técnicas de seguridad, serie 800, y las normas de buenas prácticas aplicables en su ciclo de vida.

En su implementación global, el ENS queda enmarcado en un sistema de gestión de seguridad de la información (SGSI) de ciclo continuo que refleja el proceso de mejora continua recogido en el artículo 27 del PRD (artículo 26 en el RD 3/2010): «el proceso integral de seguridad implantado deberá ser actualizado y mejorado de forma continua. Para ello, se aplicarán los criterios y métodos reconocidos relativos a gestión de la seguridad de las tecnologías de la información» (art. 27, PRD).

A continuación, se detallan los contenidos de cada fase (se incluyen referencias al RD 3/2010).

Fase de plan de adecuación al ENS *(plan)*

El RD 3/2010 y la Guía CCN-STIC-806 establecen que el contenido mínimo del plan de adecuación será el siguiente:

- Una **política de seguridad** que deberá cumplir los requisitos establecidos en el Anexo II del RD 3/2010 o bien detalle de las acciones y contenidos previstos para que sea conforme con este. Sus contenidos y características se describen en el documento CCN-STIC-805.

- Un **inventario de la información que se maneja** con su valoración conforme a los requisitos del RD 3/2010, detallados en la Guía CCN-STIC-803.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

- Un **inventario de los servicios que se prestan** con su valoración conforme a los requisitos del RD 3/2010, detallados en la Guía CCN-STIC-803.

- **Información detallada acerca de los datos de carácter personal que son tratados.** Aun cuando la Guía CCN-STIC-806 admite que el plan de adecuación simplemente direccione el documento de seguridad, en el presente proyecto se incluye un análisis diferencial sobre LOPD ante la explícita relación entre ENS y LOPD.

- La **categoría del sistema,** conforme a los requisitos del RD 3/2010, detallados en la Guía CCN-STIC-803.

- Una **declaración de aplicabilidad** de las medidas de seguridad incluidas en el Anexo II del RD 3/2010, detalladas en la Guía CCN-STIC-804 y actualizadas en el RD 951/2015, de 23 de octubre, de modificación del RD 3/2010.

- Un **análisis de riesgos** conforme a los requisitos del RD 3/2010 y a la categorización del sistema conforme a la Guía CCN-STIC-803. En este punto se aplica la metodología MAGERIT V3 en toda su extensión: criterios, catálogos, etc.

- Un detalle de las **insuficiencias del sistema** respecto de las medidas del Anexo II del ENS, de las medidas de la LOPD y de la existencia de riesgos no asumibles por el organismo.

- Un **plan de mejora de la seguridad** que incluya plazos estimados de ejecución para subsanar las insuficiencias detectadas.

- **Consideraciones y medidas por adoptar derivadas de la interconexión entre sistemas** de una misma organización o de organizaciones distintas.

- Se establecerá (en su caso) la **estructura del comité o los comités para la gestión y coordinación de la seguridad** detallando su ámbito de responsabilidad, los miembros y la relación con otros elementos de la organización. Se incluirá en la

© Universidad Internacional de La Rioja (UNIR)

política de seguridad.

- Se evaluará para el sistema el manejo de información de terceros y la prestación de servicios a terceros a los efectos de la aplicación de lo establecido en el apartado 4 de la Guía CCN-STIC-806 sobre **interconexión de sistemas.**

El plan de adecuación, que incluirá todo lo anterior, deberá ser aprobado por los órganos superiores competentes. Las acciones resultantes del plan de adecuación permitirán descubrir las necesidades detalladas y orientar las acciones derivadas de las mismas para dar cumplimiento a los requisitos del ENS.

Fase de implantación *(do)*

Una vez se ha definido el plan de adecuación, se trata de implantar o implementar cuanto en él se recoge. Esto supone:

- **Revisar y actualizar el análisis de riesgos** redefiniendo los activos englobados en el análisis de riesgos.
- Establecer y **redefinir las dependencias entre los activos** y **reevaluar su valor.**
- **Capacitar a los responsables** para el cumplimiento de sus roles.
- **Concienciar a los usuarios** del sistema de información en materia de seguridad.
- **Definir e implantar los procedimientos** operativos derivados del análisis de mejora.

Algunos ejemplos de procedimientos que se han de implantar:

© Universidad Internacional de La Rioja (UNIR)

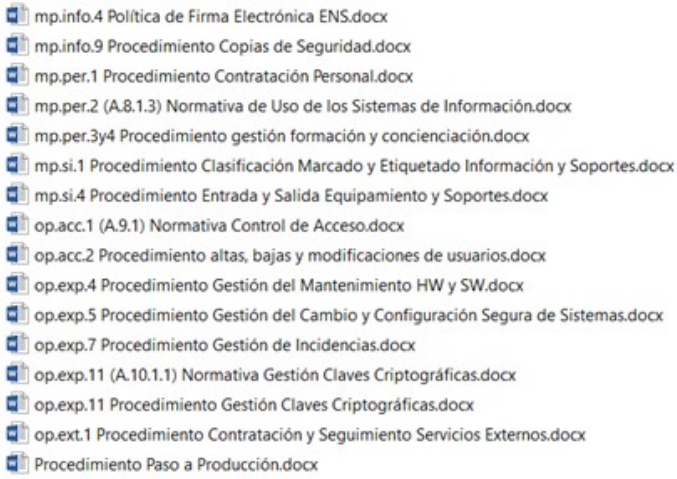


Figura 5. Procedimientos (I). Fuente: elaboración propia.

En el caso de continuidad:

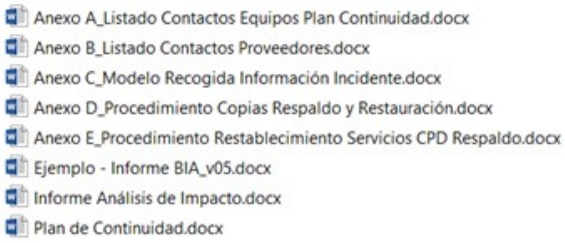


Figura 6. Procedimientos (II). Fuente: elaboración propia.

- Definir las métricas e indicadores que ofrecerán información acerca del grado de efectividad de los controles aplicados en el tratamiento de riesgos.

- Implementación de procedimientos, detección de eventos de seguridad y relativos a la protección de datos personales, así como una respuesta ante cualquier incidente de seguridad. Definición de procedimientos de revisión y control y de revisión periódica de la eficacia del SGSI.

Fase de revisión *(check)*

Una vez implantado el sistema, se deberá proceder a su revisión, lo que supondrá

© Universidad Internacional de La Rioja (UNIR)

como mínimo abordar las siguientes actividades:

- **Monitorizar, medir, analizar y evaluar** el grado de cumplimiento de las medidas exigidas.
- **Medir la eficacia de los controles** implementados en el SGSI ENS.
- **Implementar el informe automatizado sobre el estado de la seguridad (INES)** requerido por el CCN, de forma que su obtención cíclica sea realizada de forma automática.
- Realizar **auditorías internas** a intervalos planificados para obtener información sobre el funcionamiento del SGSI ENS para verificar que: (1) es conforme con los requisitos propios de la organización para el SGSI y con los requisitos del estándar (ENS); y (2) está eficientemente implantado y mantenido con base en la consecución de los objetivos marcados.

Mejora continua *(phase act)*

Como hemos indicado, el ENS constituye un proceso de mejora continua que supone el control y ajuste de desviaciones del SGSI ENS, donde los eventos identificados como «no conformes» son analizados y documentados con el fin de evitar su repetición.

Asimismo, en este punto se recoge una cláusula/objetivo respecto a la necesidad de identificar **oportunidades de mejora** que aporten valor de forma permanente al SGSI:

- Reaccionar contra la no conformidad y cuando sea aplicable: (1) tomar acciones para controlarla y corregirla; (2) gestionar sus consecuencias.
- Evaluar las necesidades de acciones para eliminar las causas de la no conformidad con el objetivo de que no se repita u ocurra de nuevo: (1) revisando la no conformidad; (2) determinando las causas de la no conformidad; (3) determinando si

© Universidad Internacional de La Rioja (UNIR)

existen no conformidades similares o si potencialmente podrían ocurrir.

- Implementar las acciones necesarias.
- Revisar la efectividad de las acciones correctivas tomadas.
- Hacer cambios en el SGSI si fueran necesarios.

Las acciones correctivas deberán ser adecuadas y proporcionales respecto a los efectos de las no conformidades encontradas.

Procedimientos de determinación de la conformidad con el ENS

El artículo 38 del RD 311/2022 establece que:

> «los sistemas de información comprendidos en el ámbito del artículo 2 y la disposición adicional tercera de este real decreto serán objeto de un proceso para determinar su conformidad con el ENS. A tal efecto, los sistemas de categoría MEDIA o ALTA precisarán de una auditoría formal para la certificación de su conformidad, mientras que los sistemas de categoría BÁSICA solo requerirán de una autoevaluación para su declaración de la conformidad, sin perjuicio de que se puedan someter igualmente a una auditoria formal de certificación» (art. 38, PRD).

También se establece que los sujetos responsables de los sistemas de información darán **publicidad,** en los correspondientes portales de Internet a las declaraciones y certificaciones de conformidad con el ENS.

Lo anterior es similar a lo que establece el RD 3/2010 en sus artículos 34 y 41.

El CCN, conforme a lo recogido en el plan de seguridad de los sistemas de información y telecomunicaciones que soportan las administraciones públicas (PSSIAP), en su calidad de plan derivado del plan nacional de ciberseguridad y dando respuesta a lo recogido en la línea de acción 2 de la estrategia de ciberseguridad nacional, articuló a través de la guía CCN-STIC-809 el **esquema de declaración y certificación de conformidad con el ENS.**

© Universidad Internacional de La Rioja (UNIR)

La guía CCN-STIC-809 recoge los siguientes **criterios para la determinación de la conformidad** con los principios y requisitos del ENS:

> «10. El ENS, en su condición de norma legal y tal como se recoge en su artículo 3, resulta de obligado cumplimiento para todos los sistemas de su ámbito de aplicación, sin más excepciones que los sistemas que tratan la información clasificada regulada en la Ley 9/1968, de 5 de abril, de Secretos Oficiales y sus normas de desarrollo.
>
> »11. La conformidad con lo dispuesto en el ENS se alcanza satisfaciendo los mandatos contenidos en su texto articulado y mediante la adecuada implantación de las medidas de seguridad contempladas en el anexo II de la norma, previa categorización de los sistemas a proteger.
>
> »12. Las Guías CCN STIC 802 (Guía de auditoría), 804 (Guía de implantación) y 808 (Verificación del cumplimiento de las medidas en el ENS), proporcionan los elementos necesarios para definir los criterios de determinación de la conformidad, así como la implantación y verificación de las medidas de seguridad, incluyendo el proceso de auditoría.
>
> »13. La determinación de la conformidad de los sistemas de información del ámbito de aplicación del ENS con categorías MEDIA o ALTA se realizará mediante un procedimiento de auditoría formal que, con carácter ordinario, verifique el cumplimiento de los requerimientos contemplados en el ENS, al menos cada dos (2) años. Con carácter extraordinario, tal auditoría deberá realizarse siempre que se produzcan modificaciones significativas en el sistema considerado que pudieran repercutir en las medidas de seguridad que deban adoptarse, tal y como dispone el artículo 34 [artículo 38 del PRD] y el Anexo III del ENS» (CCN, 2021, pp. 2-3).

Nota importante: existe un esquema de acreditación desarrollado por ENAC en estrecha colaboración con el Ministerio de Hacienda y de Administraciones Públicas y el CCN. En la siguiente dirección web del CCN se indican las entidades que pueden realizar dichas auditorías por ser entidades de certificación acreditadas o estar en vías de acreditación para expedir certificaciones de conformidad con el ENS: https://ens.ccn.cni.es/es/certificacion/entidades-de-certificacion

> «14. Para la determinación de la conformidad de los sistemas de información del ámbito de aplicación del ENS con categoría BÁSICA bastará con la ejecución de un procedimiento de autoevaluación que, con carácter ordinario, verifique el cumplimiento de

© Universidad Internacional de La Rioja (UNIR)

los requerimientos contemplados en el ENS, al menos cada dos (2) años. Con carácter extraordinario, tal autoevaluación deberá realizarse siempre que se produzcan modificaciones significativas en el sistema considerado, que pudieran repercutir en las medidas de seguridad que deban adoptarse, tal y como disponen el artículo 34 del RD 3/2010 [artículo 38 del PRD] y el Anexo III del ENS.

»15. Siendo obligatoria la auditoría en sistemas de categorías MEDIA o ALTA, nada impide que un sistema de categoría BÁSICA se someta igualmente a una Auditoría formal de verificación de conformidad, siendo esta posibilidad siempre la deseable» (CCN, 2021, p. 3).

© Universidad Internacional de La Rioja (UNIR)

2.7. Referencias bibliográficas

Amutio, M. A. y López, P. (junio, 2022). El nuevo Esquema Nacional de Seguridad, un paso más en el fortalecimiento de la ciberseguridad del sector público. *Revista de Ciberseguridad, Seguridad de la Información y Privacidad*, 150, pp. 86-88. https://www.ccn-cert.cni.es/comunicacion-eventos/articulos-y-reportajes/6627-el-nuevo-esquema-nacional-de-seguridad-un-paso-mas-en-el-fortalecimiento-de-la-ciberseguridad-del-sector-publico/file.html

Centro Criptológico Nacional. (2016a). *Guía de Seguridad (CCN-STIC-800). Esquema Nacional de Seguridad. Glosario de términos y abreviaturas.* Ministerio de la Presidencia. https://www.ccn-cert.cni.es/series-ccn-stic/800-guia-esquema-nacional-de-seguridad/499-ccn-stic-800-glosario-de-terminos-y-abreviaturas-del-ens/file.html

Centro Criptológico Nacional. (2016b). *Guía de Seguridad (CCN-STIC-830). Ámbito de aplicación del Esquema Nacional de Seguridad.* Ministerio de la Presidencia y C C N . https://www.ccn-cert.cni.es/pdf/guias/series-ccn-stic/guias-de-acceso-publico-ccn-stic/1674-ccn-stic-830-ambito-aplicacion-ens/file.html

Centro Criptológico Nacional. (2017). *Guía de Seguridad de las TIC CCN-STIC 803. ENS. Valoración de los sistemas.* Ministerio de la Presidencia y para las Administraciones Territoriales. https://contrataciondelestado.es/wps/wcm/connect/955e19c5-6bd0-4ec6-a23b-60ed7843f947/DOC20200720143500Anexo+V+-+803_ENS-valoracion_fdo.pdf?MOD=AJPERES

Centro Criptológico Nacional. (2021). *Guía de Seguridad de las TIC CCN-STIC 809. Declaración, certificación y aprobación provisional de conformidad con el ENS y distintivos de cumplimiento.* Ministerio de Defensa y CCN. https://www.ccn-

© Universidad Internacional de La Rioja (UNIR)

cert.cni.es/series-ccn-stic/800-guia-esquema-nacional-de-seguridad/1279-ccn-stic-809-declaracion-de-conformidad-con-el-ens/file.html

Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas. *Boletín Oficial del Estado,* 236, de 2 de octubre de 2015. https://www.boe.es/eli/es/l/2015/10/01/39/con

Ley 40/2015, de 1 de octubre, de Régimen Jurídico del Sector Público. *Boletín Oficial del Estado,* 236, de 2 de octubre de 2015. https://www.boe.es/eli/es/l/2015/10/01/40/con

Nexus Integra. (2022). Nexus Integra y el Esquema Nacional de Seguridad (ENS). *Nexus Integra.* https://nexusintegra.io/es/nexus-integra-y-el-esquema-nacional-de-seguridad-ens/

Poveda, J. M. (s. f.). Módulo 7: los activos de seguridad de la información. https://jmpovedar.files.wordpress.com/2011/03/mc3b3dulo-7.pdf

Real Decreto 311/2022 por el que se regula el Esquema Nacional de Seguridad. https://www.boe.es/diario_boe/txt.php?id=BOE-A-2022-7191

Real Decreto 3/2010, de 8 de enero, por el que se regula el Esquema Nacional de Seguridad en el ámbito de la Administración Electrónica. *Boletín Oficial del Estado, 25,* de 29 de enero de 2010. https://www.boe.es/eli/es/rd/2010/01/08/3/con

© Universidad Internacional de La Rioja (UNIR)

Normas y guías de la serie CCN-STIC-800

Centro Criptológico Nacional. (2022). 800 Guías Esquema Nacional de Seguridad. *CN-CERT.* https://www.ccn-cert.cni.es/guias/guias-series-ccn-stic/800-guia-esquema-nacional-de-seguridad.html

Normas y guías de la serie CCN-STIC-800 para la implementación del Esquema Nacional de Seguridad, sus medidas, su evaluación, certificación y control.

© Universidad Internacional de La Rioja (UNIR)

Portal del Centro Criptológico Nacional dedicado al ENS

Centro Criptológico Nacional Esquema Nacional de Seguridad (ENS). (2022). Página web oficial. https://ens.ccn.cni.es/es/

Portal donde el CCN ha aglutinado toda la información relativa al ENS, clasificándola en cinco grandes bloques (entorno de validación del ENS, conformidad y cumplimiento, certificación, normativa y entidades locales).

© Universidad Internacional de La Rioja (UNIR)

Test

1. ¿Cuál de los siguientes no es uno de los principios del ENS?

   A. Seguridad integral.

   B. Gestión de la seguridad basada en los riesgos.

   C. Prevención, detección, respuesta y conservación.

   D. Seguridad gestionada.

2. ¿Cuál de las siguientes afirmaciones es cierta?

   A. La integridad es la propiedad o característica consistente en que el activo de información no ha sido alterado de manera no autorizada.

   B. La integridad es la propiedad o característica consistente en que el activo de información ha sido alterado de manera no autorizada.

   C. La integridad es la propiedad o característica consistente en que la degradación que sufre el activo no supera el riesgo asumible.

   D. La integridad es la propiedad o característica consistente en que el activo de información no puede ser accesible por terceros sin autorización.

3. Indica la respuesta correcta:

   A. El ENS y la norma UNE ISO/IEC 27001:2013 difieren en su naturaleza, en su ámbito de aplicación en su obligatoriedad, pero no en sus objetivos.

   B. El ENS y la norma UNE ISO/IEC 27001:2013 difieren en su ámbito de aplicación, en su obligatoriedad y en los objetivos que persiguen, pero no en su naturaleza.

   C. El ENS y la norma UNE ISO/IEC 27001:2013 difieren en su naturaleza, en su ámbito de aplicación, en los objetivos que persiguen, pero no en su obligatoriedad.

   D. El ENS y la norma UNE ISO/IEC 27001:2013 difieren en su naturaleza, en su ámbito de aplicación, en su obligatoriedad y en los objetivos que persiguen.

© Universidad Internacional de La Rioja (UNIR)

4. Indica la respuesta correcta:

A. El ENS obliga a realizar auditorías de seguridad cuando se están evaluando sistemas o servicios cuya categoría sea de nivel medio o alto, al menos cada dos años.

B. El ENS obliga a realizar auditorías de seguridad cuando se están evaluando sistemas o servicios cuya categoría sea de nivel alto, al menos cada dos años.

C. El ENS obliga a realizar auditorías de seguridad cuando se están evaluando sistemas o servicios cuya categoría sea de nivel medio o alto, al menos cada año.

D. El ENS no obliga a realizar auditorías de seguridad.

5. ¿Cuál de las siguientes afirmaciones es cierta?

A. Las dimensiones de seguridad en el ENS son: disponibilidad, integridad, confidencialidad, trazabilidad y autenticidad.

B. Las dimensiones de seguridad en el ENS son: disponibilidad, integridad, confidencialidad, portabilidad y autenticidad.

C. Las dimensiones de seguridad en el ENS son: disponibilidad, eficiencia, confidencialidad, trazabilidad y autenticidad.

D. Las dimensiones de seguridad en el ENS son: disponibilidad, integridad, confidencialidad, concentración y autenticidad.

© Universidad Internacional de La Rioja (UNIR)

6. Indica la respuesta correcta:

A. Disponer de una certificación bajo ISO/IEC 27001 supone el cumplimiento del ENS.

B. Disponer de una certificación bajo ISO/IEC 27001 no supone el cumplimiento del ENS.

C. Disponer de una certificación bajo ISO/IEC 27001 puede suponer el cumplimiento del ENS, según el alcance de la certificación.

D. Disponer de una certificación bajo ISO/IEC 27001 puede suponer el cumplimiento del ENS, según lo estime o no la Administración pública correspondiente.

7. ¿Cuál de las siguientes afirmaciones no es cierta?

A. El ENS es una norma de obligado cumplimiento para todos los sistemas de información de las AA. PP., independientemente de su ubicación.

B. El ENS es exigible a aquellos sistemas de información operados por terceros que desarrollan funciones, misiones, cometidos o servicios para las AA. PP.

C. El ENS es exigible a aquellos sistemas de información en dependencias de terceros que desarrollan funciones, misiones, cometidos o servicios para las AA. PP.

D. El ENS es exigible solo a la Administración pública.

8. ¿Cuál de los siguientes no es un requisito básico de seguridad?

A. Profesionalidad.

B. Autorización y control de los accesos.

C. Protección de las instalaciones.

D. Control de proveedores críticos.

© Universidad Internacional de La Rioja (UNIR)

9. Indica la respuesta correcta:

A. La dimensión básica del servicio es la autenticidad.

B. La dimensión básica del servicio es la confidencialidad.

C. La dimensión básica del servicio es la integridad.

D. La dimensión básica del servicio es la disponibilidad.

10. Indica la respuesta correcta:

A. Las medidas de seguridad se dividen en tres grupos: marco organizativo, marco operacional y medidas de protección.

B. Las medidas de seguridad se dividen en tres grupos: marco organizativo, marco operacional y medidas jurídicas.

C. Las medidas de seguridad se dividen en tres grupos: marco organizativo, marco jurídico y medidas tecnológicas.

D. Las medidas de seguridad se dividen en tres grupos: marco organizativo, marco técnico y marco reputacional.

© Universidad Internacional de La Rioja (UNIR)